HERNETIQ | MISSION S29

Enterprise Compliance Gap Analysis

NovaPay AI | Board and investor version | 28 October 2026

OVERALL RISK: HIGH | GAPS IDENTIFIED: 4

Executive Summary

The review identified **four material governance gaps** affecting customer-data separation, training-data approval, model-release controls, and fairness and performance monitoring. The overall risk rating is **HIGH** because these gaps could expose client information or allow unreviewed or deteriorating credit and fraud decisions to affect customers. **Board direction:** require the CTO to pause automatic model releases until the data checks, customer access controls and pre-release review have been evidenced.

Findings

1. Customer data separation

Customer confidentiality is at risk. The policy promises that each enterprise client can access only its own records, but the reviewed process does not visibly confirm that the business requesting records is the same client that signed in. No live cross-client access was reproduced. If the service is within the EU AI Act and qualifies as high-risk, **Article 15** requires appropriate cybersecurity and **Article 9** requires documented risk management. **Action:** the CTO should direct an independent customer-access review within 7 days.

2. Unreviewed training data

Credit decisions may be degraded or biased. The policy requires approval for external data, yet one unreviewed source without documented reliability checks or a fairness review was enabled; records show it was included in the 1 October 2024 model update. This does not prove that the source caused a later incident. Where the high-risk rules apply, **Article 10** requires suitable governance and quality of data used to develop and check applicable high-risk systems, and **Article 9** requires risks to be assessed and addressed. **Action:** the data-platform owner should disable the source until approval and required checks are complete, within 14 days.

3. Model releases without evidenced approval

A harmful model change could reach customers before its risks are understood. The policy requires evaluation before release, while records show the credit and fraud models were automatically placed into live use on 1 October 2024; the reviewed material does not evidence a pre-release approval gate. A fraud regression was reported after the run, but its cause remains unconfirmed. Where applicable, **Article 9** requires an ongoing risk-management system and **Article 43** sets the relevant conformity-assessment procedure for high-risk systems before market placement or putting into service. **Action:** the CTO and model owner should block unapproved releases before the next promotion and no later than 7 days.

4. Fairness and drift monitoring gaps

Unfair or deteriorating decisions may go unnoticed. The model documentation says fairness evaluation is incomplete and uneven data coverage may disadvantage some regions; automatic alerts for significant changes in decision patterns are not configured. One open incident records an approval rate 34% above the national baseline in Lagos Southwest, while a separate fraud issue also remains open. Neither root cause is established. Where applicable, **Article 10** addresses the quality and governance of data used by applicable high-risk systems, while **Article 9** requires risk management throughout the system lifecycle. **Action:** the model-risk owner should triage both incidents within 48 hours and deliver fairness and monitoring evidence within 14 days.

Regulatory Exposure

The provisions below are potential exposure areas, not a conclusion that NovaPay has breached the EU AI Act. Applicability and system classification require legal confirmation.

Gap	EU AI Act article	Requirement and relevance
Customer data separation	Article 15 - Accuracy, robustness and cybersecurity; Article 9 - Risk management	High-risk systems must maintain appropriate cybersecurity; Article 9 requires risks to be identified, evaluated and addressed. Applicability to NovaPay must be confirmed.
Unreviewed training data	Article 10 - Data and data governance; Article 9 - Risk management	For applicable high-risk systems, training, validation and test datasets must meet prescribed quality criteria, and risk controls must address identified risks.
Model releases without evidenced approval	Article 9 - Risk management; Article 43 - Conformity assessment	Article 9 requires a documented lifecycle risk-management process. Article 43 sets the required conformity-assessment route for applicable high-risk systems before placing on the market or putting into service; it does not by itself mean every routine retraining requires a new assessment.
Fairness and drift monitoring gaps	Article 10 - Data and data governance; Article 9 - Risk management	Relevant high-risk systems need suitable data governance and a maintained process for identifying, evaluating and addressing risks over the lifecycle.

Legal-scope check: *Annex III, point 5(b), covers AI used to assess the creditworthiness of natural persons or establish their credit score. The reviewed case describes SME loan applications and does not settle affected-person or EU territorial scope. Legal/compliance should confirm intended use and scope before treating the provisions as binding obligations. Official text: Regulation (EU) 2024/1689.*

Recommended Actions

1. Protect client records. Owner: CTO / API engineering lead. **Timeframe:** Within 7 days. **Measurable outcome:** Deliver a documented independent review and passing tests showing that one client cannot view another client's records; block release until the evidence is accepted.

2. Stop unreviewed data use. Owner: Data-platform / model-operations lead. **Timeframe:** Disable immediately; complete within 14 days. **Measurable outcome:** The unreviewed source remains disabled until documented approval, integrity checks, data-quality checks and fairness review are complete; failed checks must stop processing.

3. Gate model releases. Owner: CTO and model-platform owner. **Timeframe:** Before the next production release; no later than 7 days. **Measurable outcome:** Every release has recorded evaluation results, a named approver, version information and a tested rollback path; an absent approval prevents release.

4. Resolve monitoring gaps. Owner: Model-risk lead with credit and fraud model owners. **Timeframe:** Assign incident owners within 48 hours; complete within 14 days. **Measurable outcome:** Both incidents have documented triage decisions and owners; postcode fairness results, thresholds for significant changes in decision patterns and a successful alert test are retained.

Basis: the four findings in the Week 14 NovaPay governance gap assessment and the supplied S28/S29 notes. This report does not claim live production testing or establish the root cause of either open incident.